OpenShift Workload Guidelines and Best Practices

All Workloads

Summary

While each Kubernetes Workload resource has their own guidelines and best practices, the following describes guidelines and best practices that apply to ALL Kubernetes Workload Resources deployed to OpenShift. The term "workload" applies to Deployments, StatefulSets, Jobs, CronJobs and DaemonSets.

Reference Documentation

- IRIS | Information Security Standards
- Trusted Registries
- Least-Privileged Network Controls **(TODO: Link to ServiceNow Form, add Link to Guideline)**
- OpenShift Persistent Volume Claim (PVC) Guidelines and Best Practices
- Startup, Readiness and Liveness Probes Best Practices
- OpenShift Resource Common Metadata
- How to Right-Size your OpenShift Project

Workload Guidelines

- Workload must define appropriate Memory and CPU Requests
- Workload must define appropriate Memory and CPU Limits
- Workload must define Readiness and Liveness probes
- Workload must store Secrets (sensitive data) in Kubernetes secret
    - Reference IRIS | Information Security Standards
- Workload must store Config in Kubernetes configmap and/or secret
- Referenced Image must come from a Trusted Registry
- Referenced Image must meet FCB Threat and Vulnerability Management standards
- Unused Kubernetes resources must be removed from the platform
- Workload must be able to run as any ID
- Workload must run as a non-privileged user
- Workload must not mount volume mapped to a path on the host
- Workload declaring a PodDisruptionBudget must set **maxUnavailable** to a value greater than 0 and **minAvailable** less than replica count
- Persistent data must be stored in a stateful backing service or a persistent volume (PVC)
- Logs must go to stdout/stderr
- Sensitive data must not be logged, per bank policy
- Sensitive data must not be stored in the image

Workload Best Practices

- Java workloads should be executed/instantiated via a shell script
- When declaring a PodDisruptionBudget utilize percentages
- Define a Startup probe
- If a Startup probe is not defined, use **initialDelaySeconds** on the Liveness probe to avoid rescheduling during startup
- Use memory bound **emptyDir** for temporary storage
- Consider a Persistent Volume (PVC) for large files
- Right-size your pod compute resources (CPU, memory)
    - How to Right-Size your OpenShift Project
- Define a **terminationGracePeriodSeconds** to allow for graceful pod shutdown (default is 30s)

Workload Anti-Patterns

- Storing secrets (sensitive data) in a Kubernetes Configmap
- Storing cleartext (including base64-encoded) secrets (sensitive data) in Environment variables
- Excessive Resource Requests (requests are guaranteed to the workload)
- Running of service as pid 0
    - Execution of java binary outside of shell script

Development Guidelines

- Persistent data must be stored in a stateful backing service or a persistent volume (PVC)
- Logs must go to stdout/stderr
- Sensitive data must not be logged, per bank policy
- Sensitive data must not be stored in the image

Development Best Practices

- Separate Config from Code
    - Examples:
        - Credentials, API Keys, Tokens
        - Resource handles to backing services

        - Environment-specific values
        - Per-deploy values
- Build the code and image once, promote and run the same through the environments
- Process(es) should be idempotent
- Processes should be designed to scale horizontally
- Running instances should be disposable, meaning they can be started or stopped at a moment's notice
- Memory or the container's local file system should only be used as a brief, single transaction cache
    - Except when using a PVC
- Minimize the startup time
- Include Startup, Liveness and Readiness checks (probes) that indicate the current state of the instance (replica)
    - **Startup** should indicate whether the instance (replica) has started
    - **Readiness** should indicate whether the instance (replica) is ready to accept traffic
    - **Liveness** should indicate the health of the instance (replica), signaling a restart after repeated failures
        - Note: A Liveness probe should only fail when a restart of the instance (replica), after repeated failures, would resolve some problem
- Processes should shut down gracefully when a SIGTERM is received
- Utilize Linux standard logging/minimize log lines

Development Anti-Patterns

- Logging to disk
- Running debug logging in production
- Storing cleartext or base64-encoded sensitive data in Environment variables